LABORATUVAR 6 · MİRKA SMART WOODSANDER 5000 · Ahşap Zımpara Makinesi

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad: _____ Grup: _____ Tarih: ___/___/2026

Senaryo: Saat **10:15**. WoodSander'ın servis hesabına gece 03:00'te tanınmayan bir konumdan girilmiş. PLC konfigürasyonu değişmiş olabilir; **ışık perdesi/kapak kilidi parametreleri henüz doğrulanmadı**. Makine çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1 10:15 — ilk 15 dk: Kimi ararsınız? İlk üç eyleminiz?

Aranacaklar: emniyet/bakım sorumlusu, OT/BT güvenlik sorumlusu, üretim müdürü; makine üreticisi/servis (talebe göre).

İlk üç eylem: 1) Makineyi **kontrollü ve güvenli şekilde** durdur (acil stop değil, mümkünse normal güvenli duruş; kimse kafaların yakınında değil) — emniyet doğrulanana kadar çalışmaya devam ettirme. **2)** Uzak bakım bağlantısını **ağdan ayır** (kabloyu/VPN'i kes; cihazı kapatma, resetleme). **3)** Saati, kim-ne-gördü notunu al; olay kaydı aç; hiçbir şeyi silme/resetleme.

2 İlk 2 saat: Emniyet fonksiyonu güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?

- **Doğrulama:** Safety PLC konfigürasyon CRC/imza + sürümünü son onaylı yedekle karşılaştır; kapak kilidi, ışık perdesi, acil stop ve durma süresi için **fonksiyon testi** (makine durmuş ve korumalı iken). Test geçene kadar çalıştırma yok.
- **Korunacak kanıt:** uzak bakım modülü ve VPN/firewall logları, PLC/HMI log ve konfigürasyon kopyası (salt-okunur imaj), oturum kayıtları, saat damgalı notlar. **Resetleme/yeniden başlatma yok.**
- **Kapatılacak:** tanınmayan girişte kullanılan servis hesabı (ve paylaşılan admin/admin); ilgili parolalar/anahtarlar döndürülür.

3 24 saat — CRA erken uyarı: Hangi bilgi hazır olmalı?

Olayın **şüphelenilen kötü niyetli/aktif sömürü** olup olmadığı, **etkilenen ürün/sürüm** (WoodSander 5000, firmware), ilk tespit zamanı, bilinen etkiler (emniyet fonksiyonu etkilendi mi?), **etkilenen ülkeler/müşteriler** (biliniyorsa), alınan acil önlemler, sorumlu iletişim kişisi. Kesin kök neden gerekmez — hız önemli.

4 72 saat — CRA bildirim: Kök neden, etki, önlem — kim ne yapıyor?

- **OT/Güvenlik ekibi:** kök neden analizi (giriş yolu, zayıf hesap, açık servis), log incelemesi.
- **Emniyet sorumlusu:** emniyet etkisi, yeniden validasyon sonucu ve çalışana risk değerlendirmesi.
- **Ürün/Yazılım ekibi:** açık ise yama/azaltma planı; **Yönetim/Uyum:** resmi bildirimi iletir ve müşterileri bilgilendirir; önlem listesi (hesap, erişim kapatma, izleme) sahiplerine atanır.

5 14 gün — son rapor: Hangi loglar/kayıtlar korunmuş olmalı?

Uzak erişim/VPN/jump server oturum kayıtları, firewall ve PLC/HMI logları, konfigürasyon (önce/sonra) kopyaları ve hash'leri, hesap işlem kayıtları, emniyet fonksiyon test raporları, kronoloji (olay zaman çizelgesi), alınan düzeltici önlemler ve yama/validasyon kanıtları. *Not: CRA'da nihai rapor süresi olay türüne göre değişebilir (14 gün sömürülen açık için; ciddi olaylarda genellikle bildirimden sonra ~1 ay) — güncel yükümlülüğü hukuk/uyum ekibiyle teyit edin.*

En sık hata: “Resetleyip devam edelim” — o düğme, kanıtı sonsuza dek siler. **Önce emniyet, hemen sonra kanıt.**

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.